MF0487_3 · AUDITORÍA DE SEGURIDAD INFORMÁTICA

LABORATORIO 1

Reconocimiento y Descubrimiento de Activos

Plataforma: Kali Linux Purple + Metasploitable 2
Normativa: MAGERIT v3 · ENS · ISO 27001:2022 · RGPD · LOPDGDD
Duración estimada: 3 horas · Nivel: Intermedio

⚠ **Este documento es de uso exclusivo en entornos de laboratorio controlado.**

0. FICHA TÉCNICA DEL LABORATORIO

Código	LAB-01	**UDs**	UD3, UD4
Título	Reconocimiento y Descubrimiento de Activos	**Duración**	3 h
Normativa	MAGERIT v3 · ENS · ISO 27001:2022 · RGPD art. 32	**Nivel**	Intermedio
Herramientas	Nmap, Netdiscover, Maltego CE	**Modalidad**	Individual
Objetivo	*Realizar el reconocimiento completo de una red de laboratorio, identificar activos e iniciar la construcción del inventario de activos conforme a MAGERIT v3.*		

1. MARCO NORMATIVO Y CONTEXTO LEGAL

Toda actividad de auditoría técnica en España debe enmarcarse dentro del conjunto normativo que regula el tratamiento de sistemas de información. Este laboratorio aplica las siguientes referencias:

1.1 Normativa Española y Europea aplicable

Las bases legales que habilitan y limitan las actividades de reconocimiento en el ámbito de la auditoría son:

- Código Penal (art. 197 bis): tipifica el acceso no autorizado a sistemas informáticos. Cualquier técnica de reconocimiento debe realizarse sobre sistemas propios o con autorización escrita explícita.
- RGPD (Reglamento UE 2016/679), art. 32: obliga a realizar análisis técnicos periódicos para verificar la eficacia de las medidas de seguridad.
- LOPDGDD (LO 3/2018): adaptación española del RGPD. Las auditorías técnicas son un mecanismo de cumplimiento.
- ENS — Esquema Nacional de Seguridad (RD 311/2022): obligatorio en el sector público. El reconocimiento de activos es paso previo al análisis de riesgos (medida op.pl.1).
- MAGERIT v3 (CCN-CERT, 2012): metodología de análisis de riesgos de referencia en España. El inventario de activos es la fase inicial del método.
- ISO 27001:2022, cláusula 8.2: exige una evaluación de riesgos de seguridad de la información basada en la identificación previa de activos.

1.2 Autorización y entorno controlado

⚠ **AVISO LEGAL:** Este laboratorio debe ejecutarse ÚNICAMENTE en el entorno aislado descrito en la sección 3. Aplicar estas técnicas sobre sistemas ajenos sin autorización expresa constituye un delito tipificado en el artículo 197 bis del Código Penal español, con penas de hasta 2 años de prisión.

La autorización para este laboratorio queda acreditada por:

- El entorno de laboratorio (Kali Linux Purple + Metasploitable 2) es propiedad del centro de formación y está completamente aislado de Internet.
- Metasploitable 2 incluye múltiples servicios y aplicaciones web vulnerables (DVWA, Mutillidae, Tomcat, etc.) diseñados específicamente para ser auditados.

2. OBJETIVOS DE APRENDIZAJE

2.1 Objetivos generales

- Comprender el proceso de identificación y valoración de activos según la metodología MAGERIT v3.
- Aplicar técnicas de reconocimiento pasivo y activo dentro de un proceso de auditoría estructurado.
- Relacionar los hallazgos técnicos con el marco normativo (ENS, ISO 27001:2022, RGPD).

2.2 Objetivos específicos (competencias del MF0487_3)

- UD3 — Análisis de Riesgos: Identificar activos involucrados en el análisis de riesgos y realizar su valoración inicial.
- UD4 — Herramientas: Utilizar herramientas de análisis de red, puertos y servicios (Nmap, Netdiscover) con criterio profesional.
- UD6 — Fases de la auditoría: Aplicar la guía para pruebas de auditoría y la elaboración de evidencias documentadas.

2.3 Resultados esperados

Al finalizar el laboratorio el alumno será capaz de:

- Construir el inventario inicial de activos de una red siguiendo la estructura de MAGERIT v3.
- Documentar hallazgos con evidencias (capturas, exports) conforme al estándar de un informe de auditoría profesional.
- Justificar el uso de cada herramienta en el contexto de un plan de auditoría real.

3. ENTORNO DE LABORATORIO

3.1 Arquitectura del entorno

El laboratorio utiliza dos máquinas virtuales en la misma red de aula. Anota las IPs asignadas por el instructor antes de comenzar:

Máquina / Servicio	IP (anotar)	Rol en el laboratorio
Kali Linux Purple	Anotar: _____	Máquina auditora. Lanza todas las herramientas de reconocimiento.
Metasploitable 2	Anotar: _____	Objetivo. Proporciona los servicios y aplicaciones web a auditar (incluye DVWA, Mutillidae, Tomcat, etc.).

> ℹ Metasploitable 2 debe estar arrancada y visible en red antes de comenzar. Verifica la IP con el instructor o con: sudo netdiscover -r <subred_aula>/24 -i <IFACE>

3.2 Verificación del entorno

Antes de iniciar las tareas, comprueba la conectividad desde Kali Purple:

```
ping -c 2 <IP_META>    # Metasploitable 2
```

Debe responder. Si no responde, verifica la IP con el instructor antes de continuar.

3.3 Herramientas requeridas

Las siguientes herramientas deben estar disponibles en Kali Linux Purple. Verifica su instalación:

```
nmap --version && netdiscover --help 2>&1 | head -1 && maltego --help 2>&1 | head -
1
```

Si alguna herramienta no está disponible:

```
sudo apt update && sudo apt install -y nmap netdiscover
```

4. DESARROLLO DEL LABORATORIO

ℹ Documenta cada tarea con capturas de pantalla numeradas. Las evidencias son obligatorias para la evaluación.

TAREA 1 — Reconocimiento Pasivo de la Red (30 min)

1.1 Descubrimiento de hosts con Netdiscover

Netdiscover usa peticiones ARP para descubrir hosts activos sin generar tráfico TCP/UDP — técnica de reconocimiento pasivo menos detectable.

Justificación MAGERIT v3: corresponde a la fase de Identificación de Activos (Libro II, cap. 2.1).

Ejecuta el siguiente comando y espera al menos 60 segundos:

```
sudo netdiscover -r <subred_aula>/24 -i <IFACE>
```

Registra los resultados en la siguiente tabla:

IP Descubierta	MAC Address	Fabricante (OUI)	Tipo de Activo (MAGERIT)
<IP_KALI> (Kali)	_	_	SW — Software base (SO)
<IP_META> (Metasploitable 2)	_	_	_
(otros)	_	_	_

Referencia MAGERIT v3 — Tipos de activo:

- HW — Hardware (equipos físicos)
- SW — Software (sistemas operativos, aplicaciones)
- COM — Redes de comunicaciones
- S — Servicios

1.2 Reconocimiento inicial con Nmap (ping scan)

El ping scan de Nmap confirma qué hosts responden sin realizar enumeración de puertos:

```
sudo nmap -sn <subred_aula>/24 -oN ~/lab01/fase1_pingscan.txt
```

Guarda el fichero de salida. Será parte de las evidencias del informe.

⚠ **AVISO LEGAL:** El flag -sn solo realiza descubrimiento de hosts. No uses opciones de escaneo de puertos en esta fase — el reconocimiento debe ser gradual y proporcional, como en una auditoría real.

TAREA 2 — Enumeración de Puertos y Servicios (45 min)

2.1 Escaneo de puertos TCP — Metasploitable 2

Objetivo: construir el mapa de servicios del sistema Metasploitable 2, que actuará como activo principal en análisis posteriores.

Escaneo de los 1000 puertos más comunes con detección de versión:

```
sudo nmap -sV -sC -T3 <IP_META> -oN ~/lab01/fase2_metasploitable_sV.txt
```

Escaneo completo de los 65535 puertos (ejecutar en segundo plano):

```
sudo nmap -p- -T3 <IP_META> -oN ~/lab01/fase2_metasploitable_full.txt &
```

> ℹ El flag -T3 establece una velocidad de escaneo moderada. En auditorías reales se evita -T4/-T5 sin autorización para no impactar la disponibilidad del sistema objetivo (relevante para el ENS, medida op.cont.2).

Registra los servicios encontrados:

Puerto/Proto	Estado	Servicio	Versión detectada	Riesgo inicial (A/M/B)
21/tcp	open	FTP	_	_
22/tcp	open	SSH	_	_
23/tcp	open	Telnet	_	_
80/tcp	open	HTTP	_	_
...	...	...	...	...

2.2 Aplicaciones web en Metasploitable 2

Metasploitable 2 aloja varias aplicaciones web que serán objetivo en laboratorios posteriores (LAB-04). Verifica su disponibilidad:

```
sudo nmap -sV -p 80,443,8080,8180 <IP_META> -oN ~/lab01/fase2_webapps.txt
```

```
sudo nmap --script http-headers,http-title <IP_META> -p 80,8180 -oN
~/lab01/fase2_http_titles.txt
```

¿Qué tecnologías web detecta Nmap? Anótalas y busca su versión en la base de datos CVE: https://nvd.nist.gov

TAREA 3 — Detección de Sistema Operativo y Fingerprinting (30 min)

3.1 OS Detection

La detección del sistema operativo permite clasificar el activo y anticipar vulnerabilidades específicas de la plataforma:

```
sudo nmap -O <IP_META> -oN ~/lab01/fase3_osdetection.txt
```

Parámetros avanzados para fingerprinting completo:

```
sudo nmap -A <IP_META> -oN ~/lab01/fase3_aggressive.txt
```

> ⚠ **AVISO LEGAL:** El flag -A activa OS detection, version detection, script scanning y traceroute simultáneamente. En entornos reales su uso requiere autorización explícita en el plan de auditoría y debe documentarse.

3.2 Análisis con scripts NSE

Los NSE Scripts (Nmap Scripting Engine) permiten obtener información adicional de servicios específicos:

```
sudo nmap --script vuln <IP_META> -p 21,22,80 -oN ~/lab01/fase3_vuln_scripts.txt
```

Scripts específicos por servicio:

```
sudo nmap --script ftp-anon,ftp-bounce <IP_META> -p 21
sudo nmap --script http-enum,http-robots.txt <IP_META> -p 80
```

> ℹ El script vuln ejecuta comprobaciones básicas de vulnerabilidades conocidas. Los resultados son indicativos — deben confirmarse con OpenVAS en el LAB-02. Esta es la diferencia entre prueba sustantiva (evidencia directa) y prueba de cumplimiento (verificación de control).

TAREA 4 — Construcción del Inventario de Activos MAGERIT v3 (45 min)

Esta tarea integra los resultados de las fases anteriores en el formato de inventario de activos que exige MAGERIT v3. Este inventario es el producto principal del Laboratorio 1 y la base de los análisis de riesgo posteriores.

4.1 Estructura del inventario MAGERIT v3

MAGERIT v3 (Libro II — Catálogo de Elementos) define los siguientes atributos para cada activo:

Atributo MAGERIT	Descripción	Ejemplo
Identificador	Código único del activo	HW-01, SW-02, S-03
Nombre	Denominación descriptiva	Servidor Web Metasploitable
Tipo	Categoría MAGERIT (HW/SW/S/COM/D)	SW — Software
Descripción	Función en el sistema	Sistema Linux con servicios vulnerables
Valoración D	Disponibilidad (0-10)	7
Valoración I	Integridad (0-10)	8
Valoración C	Confidencialidad (0-10)	9
Dependencias	Activos de los que depende	HW-01, COM-01
Responsable	Propietario del activo	Administrador de sistemas

4.2 Construcción del inventario

Completa la siguiente tabla con los activos identificados en las Tareas 1-3:

ID	Nombre	Tipo	IP/Localiz.	Valor D	Valor I	Valor C	Dependencias
HW-01	Servidor Metasploitable 2	HW	<IP_META>	_	_	_	COM-01
SW-01	Linux Ubuntu (Metasploitable)	SW	<IP_META>	_	_	_	HW-01
S-01	Servicio FTP	S	<IP_META>:21	_	_	_	SW-01
S-02	Servicio HTTP / DVWA / Mutillidae	S	<IP_META>:80	_	_	_	SW-01
S-03	Servicio SSH	S	<IP_META>:22	_	_	_	SW-01
S-04	Tomcat Manager	S	<IP_META>:8180	_	_	_	SW-01
COM-01	Red de aula	COM	<subred_aula>/24	_	_	_	—

ℹ La escala de valoración MAGERIT v3 va de 0 (sin valor) a 10 (valor muy alto). Consulta el Libro II, Apéndice 3 para los criterios de valoración de las dimensiones D, I, C, A (autenticidad) y T (trazabilidad).

4.3 Exportación de resultados Nmap a XML

Los resultados de Nmap en formato XML son la evidencia técnica del inventario. Genera el fichero XML consolidado:

```
sudo nmap -sV -O <IP_META> -oX ~/lab01/inventario_activos.xml
```

Este fichero XML se importará en OpenVAS en el LAB-02 como base de partida para el análisis de vulnerabilidades.

TAREA 5 — Análisis de Relaciones con Maltego CE (30 min)

Maltego permite visualizar las relaciones entre activos de forma gráfica, facilitando la comprensión de la superficie de ataque. En Kali Purple viene incluido en la versión Community Edition.

5.1 Configuración inicial

- Abre Maltego CE desde el menú de Kali Purple o ejecutando: maltego en terminal.
- Si es la primera vez, crea una cuenta gratuita en https://www.maltego.com/ce-registration/
- Selecciona New Graph para iniciar un grafo en blanco.

5.2 Construcción del grafo de activos

Sigue estos pasos para mapear visualmente el entorno de laboratorio:

- Arrastra un elemento 'IPv4 Address' al lienzo e introduce <IP_META>.
- Clic derecho → Run Transform → 'To Ports and Services' (si está disponible en CE).
- Añade manualmente los servicios como entidades 'Service' conectadas a la IP.
- Añade una segunda entidad IP con <IP_META> para representar Metasploitable 2 completa.
- Añade una entidad 'Network' para representar la red de aula (<subred_aula>/24).

El grafo resultante debe mostrar visualmente la topología descubierta y las relaciones entre activos, servicios y la red.

> ℹ En auditorías reales de empresas, Maltego CE permite también OSINT (búsqueda de dominios, emails, infraestructura pública). En este laboratorio lo usamos solo para el grafo interno, pero la metodología es idéntica.

5.3 Exportación del grafo

Exporta el grafo como imagen PNG:

- File → Export Graph → As Image (PNG)
- Guarda como ~/lab01/grafo_activos_maltego.png
- Esta imagen formará parte del informe de auditoría como Figura 1.

5. ENTREGABLE — INFORME DE RECONOCIMIENTO

El entregable de este laboratorio es un informe de reconocimiento profesional que debe contener las siguientes secciones. Sigue la estructura de la Guía CCN-STIC 817 (Gestión de ciberincidentes) adaptada a auditoría:

5.1 Estructura obligatoria del informe

- Portada: identificación del alumno, fecha, alcance del trabajo y declaración de entorno controlado.
- Resumen ejecutivo: hallazgos principales en lenguaje no técnico (máximo 1 página).
- Alcance y metodología: herramientas utilizadas, fases ejecutadas, limitaciones.
- Inventario de activos: tabla MAGERIT v3 completada (Tarea 4.2).
- Mapa de servicios: tabla de puertos y servicios (Tarea 2) con riesgos iniciales.
- Grafo de relaciones: imagen exportada de Maltego (Tarea 5.3).
- Evidencias técnicas: capturas de pantalla numeradas con descripción.
- Conclusiones y recomendaciones: mínimo 3 recomendaciones con referencia a ENS/ISO 27001.
- Ficheros adjuntos: exports XML y .txt de Nmap.

5.2 Ficheros a entregar

Comprime todo en un archivo con la siguiente nomenclatura:

```
zip LAB01_[apellido]_[nombre].zip ~/lab01/
```

Fichero	Contenido	Herramienta origen
fase1_pingscan.txt	Hosts descubiertos (ping scan)	Nmap
fase2_metasploitable_sV.txt	Puertos y versiones Metasploitable	Nmap
fase3_osdetection.txt	OS detection Metasploitable	Nmap
inventario_activos.xml	Inventario completo en XML	Nmap
grafo_activos_maltego.png	Grafo de relaciones entre activos	Maltego CE
informe_lab01.pdf	Informe de reconocimiento completo	Alumno

6. PREGUNTAS DE REFLEXIÓN

Responde brevemente las siguientes preguntas en el informe (sección 'Conclusiones'):

- ¿Qué diferencia existe entre un escaneo de tipo caja negra (black box) y caja blanca (white box) según MAGERIT v3? ¿Qué tipo de escaneo hemos realizado en este laboratorio?
- Elige tres servicios descubiertos en Metasploitable 2. Para cada uno, identifica qué dimensión de seguridad MAGERIT (Disponibilidad, Integridad o Confidencialidad) se vería más afectada si ese servicio fuese comprometido. Justifica tu respuesta.
- El artículo 32 del RGPD obliga a los responsables del tratamiento a implementar medidas técnicas para garantizar la seguridad. ¿De qué manera contribuye un inventario de activos actualizado al cumplimiento de este artículo?
- Compara la información obtenida con Netdiscover vs. Nmap -sn. ¿Cuándo usarías uno frente al otro en una auditoría real?
- ¿Qué riesgo legal asumes si realizas un escaneo Nmap con el flag -A sobre un sistema sin autorización previa? Cita el artículo del Código Penal aplicable.

7. RÚBRICA DE EVALUACIÓN

Inventario de activos (30%)	Incompleto o sin formato MAGERIT	Activos identificados, valoración básica	Inventario completo con valoración y justificación MAGERIT v3
Uso correcto de herramientas (25%)	Comandos incorrectos o sin resultado	Herramientas usadas con parámetros básicos	Parámetros optimizados, flags avanzados justificados
Documentación de evidencias (25%)	Sin capturas o irrelevantes	Capturas con descripción básica	Evidencias anotadas, numeradas y referenciadas en el informe
Marco normativo (20%)	No menciona normativa	Referencia alguna norma	Conecta cada hallazgo con MAGERIT v3, ENS o ISO 27001:2022

Nota final: media ponderada de los cuatro criterios. Se requiere un mínimo de 5 puntos en cada criterio para superar el laboratorio.

8. REFERENCIAS NORMATIVAS Y TÉCNICAS

Normativa

- CCN-CERT. MAGERIT v3 — Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro I y Libro II. Madrid: Ministerio de Hacienda y AAPP, 2012. https://www.ccn-cert.cni.es/es/series-ccn-stic/800.html
- Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad. BOE núm. 106, 2022.
- Reglamento (UE) 2016/679 del Parlamento Europeo (RGPD). DO L 119, 4.5.2016.
- Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD). BOE núm. 294, 2018.
- ISO/IEC 27001:2022. Information security management systems — Requirements.

Técnicas

- Lyon, G. (2009). Nmap Network Scanning. Nmap Project. https://nmap.org/book/
- OWASP Foundation. OWASP Testing Guide v4.2. https://owasp.org/www-project-web-security-testing-guide/
- CCN-CERT. Guía CCN-STIC 817 — Gestión de ciberincidentes. Serie CCN-STIC 800.
- NIST. SP 800-115 — Technical Guide to Information Security Testing and Assessment. 2008.